

PraxisFlow AI - Sicherheits- und Datenschutzkonzept

Version: 1.0.0 | **Datum:** 31.08.2026 | **Status:** Phase 1 – Entwurf
Klassifikation: VERTRAULICH – Nicht öffentlich zugänglich

1. Schutzgüter und Schutzbedarf

Schutzobjekt	Vertraulichkeit	Integrität	Verfügbarkeit
Patientendaten (Stamm, Kontakt)	HOCH	HOCH	MITTEL
Medizinische Vor- gänge	SEHR HOCH	SEHR HOCH	HOCH
Freigabeentscheide	SEHR HOCH	SEHR HOCH	HOCH
Audit-Protokoll	MITTEL	SEHR HOCH	HOCH
Systemkonfiguration	HOCH	HOCH	MITTEL
Zugangsdaten (Pass- wörter, Tokens)	SEHR HOCH	SEHR HOCH	MITTEL
Synthetische Pilot- daten	NIEDRIG	MITTEL	NIEDRIG

2. Bedrohungsmodell (STRIDE)

Bedrohung	Massnahme
Spoofing (Identitätsfälschung)	Auth.js Sessions, bcrypt, MFA-Vorbereitung
Tampering (Datenmanipulation)	Optimistic Locking, unveränderliches Audit-Log
Repudiation (Abstreitbarkeit)	Revisionsfähiges Audit-Log mit Zeitstempel + Person
Information Disclosure (Datenleck)	RBAC, Mandantentrennung, Feldverschlüsselung
Denial of Service	Rate Limiting, Request-Validierung
Elevation of Privilege	Serverseitige RBAC, kein Frontend-Trust

3. Sicherheitsarchitektur

3.1 Authentifizierung

- **Technologie:** Auth.js v5 (stable), serverseitig kontrollierte Sessions
- **Passwörter:** bcrypt, min. 12 Runden, min. 12 Zeichen, Komplexitätsanforderungen
- **Sessions:** Datenbankgestützte Sessions (nicht stateless JWT), sofortig widerrufbar
- **Cookies:** HttpOnly; Secure; SameSite=Strict
- **Sitzungsdauer:** 4 Stunden, Inaktivitäts-Timeout 30 Minuten
- **MFA:** TOTP vorbereitet (Auth.js Authenticator), vor Echtbetrieb aktivieren

3.2 Autorisierung (RBAC)

- Jede geschützte API-Route ruft `requirePermission(session, permission)` auf
- Keine Entscheidung basiert nur auf Client-seitigen Daten
- `tenantId` wird immer aus der validierten Session entnommen, nie aus dem Request-Body
- Berechtigungen sind in der Datenbank gespeichert und cacheoptimiert

3.3 Mandantentrennung

- Alle Datenbankabfragen enthalten `WHERE tenantId = $1` als Pflichtbedingung
- Prisma-Middleware erzwingt tenantId-Filter (kann nicht umgangen werden)
- Cross-Tenant-Zugriff ist nur für SYSADMIN erlaubt und wird protokolliert

3.4 Eingabevalidierung

- Alle Inputs werden mit Zod validiert (client- und serverseitig)
- tRPC-Input-Schemas sind Teil der API-Kontrakte
- Maximale Feldlängen für alle String-Felder definiert
- Dateiuploads: Typ-Prüfung (MIME), Grösse-Limit, Virus-Scan-Vorbereitung

3.5 OWASP Top-10 Schutzmassnahmen

OWASP	Massnahme
A01 Broken Access Control	Serverseitiges RBAC, tenantId-Pflicht
A02 Cryptographic Failures	HTTPS erzwungen, AES-256 für sensible Felder
A03 Injection	Prisma parametrisierte Queries, Zod-Validierung
A04 Insecure Design	Privacy by Design, STRIDE-Modell
A05 Security Misconfiguration	.env.example, keine Secrets im Code
A06 Vulnerable Components	Abhängigkeits-Audit via <code>npm audit</code> in CI
A07 Auth Failures	Sessions widerrufbar, bcrypt, MFA-Vorbereitung
A08 Integrity Failures	Prüfsummen für Dokumente (SHA-256)
A09 Logging Failures	Pino strukturiertes Logging, keine PII in Logs
A10 SSRF	Adapter-Whitelist, kein direkter URL-Aufruf aus Input

3.6 Rate Limiting

Endpunkt	Limit
/api/auth/login	5 Versuche / 15 Min / IP
/api/auth/reset-password	3 Versuche / 1 Stunde / IP
Allgemeine API-Requests	200 Requests / 1 Min / Benutzer
Datei-Uploads	10 Uploads / 5 Min / Benutzer

3.7 Verschlüsselung

- **Transport:** TLS 1.3 (HTTPS erzwungen, HSTS)
- **Speicherung (Felder):** AES-256-GCM für sensible Felder (AHV, Telefon, MFA-Secret)
- **Speicherung (Datenbank):** PostgreSQL `pgcrypto` oder externer KMS (vor Echtbetrieb)
- **Backups:** Verschlüsselte Backups (AES-256), getrennte Schlüsselablage

3.8 Audit-Protokoll (revisionsfähig)

- **Was wird protokolliert:** Anmeldung, Abmeldung, Lesen (Patientendaten), Erstellen, Ändern, Löschen, Exportieren, Freigeben, Eskalation, privilegierter Zugriff
- **Inhalt:** Zeitstempel (UTC), Benutzer-ID, Aktion, Ressource, Ressourcen-ID, IP, Session-ID, Ergebnis
- **Was NICHT protokolliert wird:** Klartextdaten, Passwörter, medizinische Inhalte, PII in technischen Logs
- **Unveränderlichkeit:** Audit-Tabelle hat kein `updatedAt`, kein Soft-Delete; Schreib-only via Service
- **Aufbewahrung:** min. 10 Jahre (Schweizer Anforderung)

4. Datenschutzkonzept (Privacy by Design)

4.1 Grundsätze

- **Datenminimierung:** Nur notwendige Felder; keine Profilbildung ausserhalb des Praxiskontexts
- **Zweckbindung:** Daten werden nur für den dokumentierten Zweck verwendet
- **Transparenz:** Patienten können Auskunft, Berichtigung und Löschung verlangen
- **Privacy by Default:** Restriktivste Einstellungen sind der Standard

4.2 Rechtsgrundlagen (CH)

Verarbeitung	Rechtsgrundlage
Patientenstammdaten	Vertragsverhältnis / Behandlungsauftrag
Medizinische Daten	Notwendigkeit für Behandlung
Audit-Log	Berechtigtes Interesse (Sicherheit)
Kommunikation	Einwilligung oder Vertrag

⚠ **Vor Echtbetrieb juristisch prüfen:** DSG (Schweiz), ggf. DSGVO (EU-Patientinnen und -Patienten), Kantonsrecht

4.3 Aufbewahrung und Löschung

Datentyp	Aufbewahrungsdauer	Grundlage
Patientendaten	10 Jahre nach letztem Kontakt	OR Art. 127 / Krankenkassenrecht
Medizinische Unterlagen	10 Jahre (CH)	Kantonale Gesundheitsgesetze
Audit-Logs	10 Jahre	Sicherheitsanforderung
Technische Logs	90 Tage	Betriebserfordernis
Backups	30 Tage rolling + 1 Jahres-Backup	Betriebsanforderung

4.4 KI-Datenschutz

- **Keine produktiven Patientendaten in KI-Prompts** – weder im Pilot noch in Produktion
- Im Pilot: Regelbasierte KI-Logik (kein LLM, kein externes API-Call)
- Für künftigen LLM-Einsatz: Pseudonymisierung vor Prompt-Übergabe, On-Premises oder CH/EU-Hosting

5. Sicherheits- und Datenschutz-Checkliste

5.1 Technische Massnahmen (Pilot v1)

#	Massnahme	Status	Vor Echtbetrieb prüfen
T01	HTTPS erzwungen (TLS 1.3)	✓ Geplant	
T02	HSTS-Header konfiguriert	✓ Geplant	
T03	HttpOnly/Secure/SameSite Cookies	✓ Geplant	
T04	Session-Widerruf in Datenbank	✓ Geplant	
T05	bcrypt Passwort-Hashing (12 Runden)	✓ Geplant	
T06	Zod Eingabevalidierung (server + client)	✓ Geplant	
T07	RBAC serverseitig auf jeder Route	✓ Geplant	
T08	tenantId-Pflichtfilter via Prisma-Middleware	✓ Geplant	
T09	Audit-Log unveränderlich	✓ Geplant	
T10	Rate Limiting (Login, API)	✓ Geplant	
T11	Keine Secrets im Code (.env)	✓ Geplant	
T12	.gitignore schützt .env	✓ Geplant	
T13	Prisma parametrisierte Queries	✓ Geplant	
T14	Content-Security-Policy Header	✓ Geplant	
T15	X-Frame-Options Header	✓ Geplant	

#	Massnahme	Status	Vor Echtbetrieb prüfen
T16	Strukturiertes Logging ohne PII	✓ Geplant	
T17	Dokumenten-Prüfsummen (SHA-256)	✓ Geplant	
T18	Datei-Upload Typ- und Grössenprüfung	✓ Geplant	
T19	Mock-Adapter klar als MOCK gekennzeichnet	✓ Geplant	
T20	Soft Delete für alle relevanten Entitäten	✓ Geplant	
T21	Feldverschlüsselung AHV, Telefon, MFA	🕒 Vor Echtbetrieb	✓
T22	MFA aktiviert und erzwungen	🕒 Vor Echtbetrieb	✓
T23	Penetrationstest (extern)	🕒 Vor Echtbetrieb	✓
T24	Virus-Scan für Dateiuploads	🕒 Vor Echtbetrieb	✓
T25	Backup-Verschlüsselung und -Test	🕒 Vor Echtbetrieb	✓

5.2 Organisatorische Massnahmen (⚠️ = Vor Echtbetrieb juristisch/organisatorisch prüfen)

#	Massnahme	Status	Pflicht Echtbetrieb
O01	Datenschutzbeauftragter benannt	⌚	⚠️
O02	Verzeichnis der Verarbeitungstätigkeiten	⌚	⚠️
O03	Datenschutz-Folgenabschätzung (DSFA)	⌚	⚠️
O04	Auftragsverarbeitungsvertrag (Hosting)	⌚	⚠️
O05	Mitarbeiter-Schulung Datenschutz	⌚	⚠️
O06	Passwort-Richtlinie dokumentiert	⌚	⚠️
O07	Incident-Response-Plan	⌚	⚠️
O08	Meldepflicht Datenpanne (EDÖB, 72h)	⌚	⚠️
O09	Betroffenenrechte-Prozess (Auskunft/Löschung)	⌚	⚠️
O10	Backup & Recovery getestet	⌚	⚠️
O11	Outsourcing-Verträge (APIs, Hosting)	⌚	⚠️
O12	Geheimhaltungsvereinbarungen Personal	⌚	⚠️
O13	4-Augen-Prinzip für privilegierte Zugriffe	⌚	⚠️

5.3 Vertraglich zu klärende Punkte (vor Echtbetrieb)

#	Punkt	Zuständigkeit
V01	Rockethealth: Datenschutz bei API-Anbindung	Praxisleitung + Rockethealth
V02	OneDoc: Auftragsverarbeitung	Praxisleitung + OneDoc
V03	HIN/BlueConnect: Zertifikatsvertrag	IT + HIN
V04	ESPAS: API-Nutzungsbedingungen	Praxisleitung + ESPAS
V05	Hosting: Schweizer oder EU-Datencenter	IT-Leitung
V06	LLM-API (optional): Datenschutzprüfung	Datenschutzbeauftragte/r
V07	Krankenversicherungsgesetz-Konformität	Rechtsberatung
V08	Kantonal: Datenschutz Basel-Landschaft	Rechtsberatung

6. Incident-Response (Grundstruktur)

Erkennung

- Alarm in Monitoring
- Manueller Bericht (Mitarbeiter/in)

Bewertung

- Schweregrad: Kritisch / Hoch / Mittel / Niedrig
- Betroffene Daten / Systeme identifizieren

Eindämmung

- Betroffene Sessions widerrufen
- Zugriff sperren
- Systeme isolieren (wenn nötig)

Benachrichtigung

- Praxisleitung sofort
- Datenschutzbeauftragte/r
- Bei Datenpanne: EDÖB innerhalb 72h (DSG nREV)
- Betroffene Patientinnen und Patienten (wenn risikobehaftet)

Wiederherstellung

- Backup einspielen
- System prüfen
- Freigabe

Nachbereitung

- Root-Cause-Analyse
- Massnahmenplan
- Audit-Eintrag
- Dokumentation

7. Notizen zum Pilotbetrieb

- Synthetische Daten: Kein realer Schaden bei Datenverlust
- Pilot-Umgebung: Klar als PILOT/TESTUMGEBUNG gekennzeichnet (Banner in UI)
- Kein Zugriff auf produktive Praxissysteme
- Pilot-Accounts haben kein Zugriff auf echte Integrationen
- Alle Mock-Adapter sind als [MOCK] gekennzeichnet